FINAL INCIDENT RESPONSE REPORT – CAPT ARUN PUNDIR

Operation Silent Perimeter
Prepared by: Cyber Defence Cell

---

1. What happened first? (Attack Timeline Analysis)

Based on the simulated timeline and supporting evidence:

Step-by-step sequence:

1. **Routing failure occurred (2300 hrs)**
    - Misconfiguration (OSPF ↔ EIGRP redistribution issue) caused loss of connectivity to Logistics (R3).
    - This created a **visibility gap**, allowing attacker movement.
2. **Reconnaissance phase initiated**
    - Nmap SYN scan detected (Suricata alerts expected).
    - Attacker mapped open ports/services.
3. **Credential harvesting phase**
    - Telnet and FTP logins captured via plaintext traffic (Wireshark evidence).
    - DVWA HTTP POST credentials intercepted.
4. **Unauthorized access gained**
    - Using stolen credentials, attacker accessed internal services.
5. **Data exfiltration (FTP transfer observed)**
    - Sensitive files transferred from internal server.
6. **Persistence / C2 communication established**
    - Infected laptop connected to **port 4444** (common reverse shell/backdoor port).

2. Which evidence proves credential theft?

From **Wireshark analysis document**:

- **FTP Credentials**
    - Visible USER and PASS in packets
    - Filter used: ftp / tcp contains "USER"
- **Telnet Credentials**
    - Username/password transmitted in plaintext
    - Filter: telnet

- **DVWA Login**
    - HTTP POST request captured
    - Filter: http.request.method == POST
- **Key Proof**
    - Credentials are directly readable in packet payloads
    - No encryption (confirmed in doc: SFTP attempt was encrypted and unreadable)

3. Which host was the attacker?

Based on combined indicators:

- Source of:
    - Nmap scan activity
    - Multiple port hits (Suricata rule)
    - Unauthorized connections
- Plus:
    - Laptop communicating on **port 4444**

Attacker Identification Logic:

- The host:
    - Initiating scans
    - Accessing multiple services
    - Appearing as **foreign/suspicious IP in netstat**

4. Which defensive control failed or was missing?

Multiple failures observed:

Network Security Failures

- No proper **routing validation / redundancy**
- Lack of **segmentation (flat network exposure)**

Protocol Security Failures

- Use of:
    - Telnet (plaintext)
    - FTP (plaintext)
    - HTTP (unencrypted)

Monitoring Failures

- IDS present but:
    - No **real-time response**
    - No automated blocking

Access Control Failures

- Weak authentication mechanisms
- No MFA / credential protection

5. How would you contain the incident in 10 minutes?

Immediate Actions (Priority Order)

1. **Isolate compromised system**
    - Disable network:
    - netsh interface set interface "Ethernet" admin=disable
2. **Kill malicious process (port 4444)**
    - Identify:
    - netstat -ano
    - Kill:
    - taskkill /PID <pid> /F
3. **Block attacker IP**
4. netsh advfirewall firewall add rule name="Block Attacker" dir=out action=block remoteip=<IP>
5. **Disable compromised accounts**
6. net user username /active:no
7. **Stop vulnerable services**
    - Telnet / FTP services immediately stopped
8. **Preserve evidence**
9. netstat -ano > netstat_log.txt
10. tasklist > processes.txt

6. Long-term remediation plan

Network Hardening

- Fix routing (correct redistribution between OSPF & EIGRP)
- Implement VLAN segmentation

Protocol Replacement

- Telnet → SSH
- FTP → SFTP
- HTTP → HTTPS

Endpoint Security

- Deploy EDR solutions
- Regular patching

Access Control

- Enforce:
    - Strong passwords
    - Multi-factor authentication (MFA)

Monitoring Improvements

- SIEM integration
- Real-time alerting + automated response

7. Which protocols should be replaced and why?

Protocol	Replace With	Reason
Telnet	SSH	Encrypts credentials
FTP	SFTP	Secure file transfer
HTTP	HTTPS	Protects web login data

Reason (from Wireshark doc):

- Plaintext protocols allow:
    - Sniffing
    - MITM attacks
    - Credential theft

---

8. How to improve monitoring posture?

Enhancements

1. **Advanced IDS/IPS (Suricata tuning)**
    - Detect:
        - Brute-force attempts
        - Data exfiltration
2. **Centralized Logging (SIEM)**
    - Correlate:
        - Netstat logs
        - Wireshark captures
        - IDS alerts
3. **Behavior-based Detection**
    - Detect anomalies:
        - Unusual ports (4444)
        - Lateral movement
4. **Real-time Alerting**
    - Auto-block suspicious IPs
5. **Threat Hunting**
    - Regular scan for:
        - Backdoors
        - Persistence mechanisms

Final Conclusion

The incident was a **multi-stage attack** involving:

- Initial network misconfiguration (entry window)
- Reconnaissance (Nmap scan)
- Credential theft (Telnet, FTP, HTTP)
- Unauthorized access
- Data exfiltration
- Persistence via reverse shell (port 4444)